Relatorio de Analise de Banco de Dados

Projeto: controle_gastos | Data: 2026-10-30 | Branch: main @ 0629907
SGBD: PostgreSQL 18 (imagem postgres:18-alpine) | ORM: Spring Data JPA / Hibernate | Migracoes: Flyway V1-V12
Modo: somente leitura (sem DDL/DML, sem conexao a producao, sem EXPLAIN ANALYZE)

1. Resumo executivo

A modelagem financeira esta alinhada aos ADRs: dinheiro em NUMERIC(19,2), CHECKs de dominio, locking otimista em renda/verba, tokens apenas como hash, exclusao logica de gastos e job de retencao de artefatos de identidade. Os principais gaps sao: (1) listagem de lancamentos por verba inclui gastos ja excluidos logicamente; (2) a invariante "soma das bases <= renda" nao e aplicada na criacao/atualizacao de verbas; (3) handoff OAuth mobile nao entra no job de descarte; (4) backup/restauracao e exclusao verificavel do titular permanecem pendentes na documentacao operacional.

Defeitos comprovados: DB-001, DB-002, DB-003.
Riscos estaticos: DB-004, DB-005, DB-006, DB-008.
Hipoteses / aceitar: DB-007, DB-009, DB-010.

2. Escopo, metodologia e limitacoes

- Analise estatica de migrations Flyway, entidades JPA, repositorios, servicos transacionais, compose.yaml, application.yml e docs de privacidade/ADRs.
- Ambiente de banco vivo: nao consultado. Sem volume, cardinalidade, EXPLAIN ou metricas de producao.
- gh auth: token invalido nesta sessao; issues nao serao criadas ate aprovacao + reautenticacao.
- Mudancas locais preservadas (skills nao commitadas; binario .class modificado). Nenhuma alteracao de schema/codigo nesta auditoria.

3. Visao geral do modelo de dados

Tabelas principais:

- identity: user_account, auth_session, auth_attempt, password_reset_token, totp_credential, recovery_code, mfa_login_challenge, identity_provider_link, oauth_authorization_state, oauth_mobile_handoff
- income: monthly_income (PK owner_id+effective_month, version), income_revision (append-only)
- envelopes: envelope (purpose + configuracao financeira com CHECK composto, version, archived_at), envelope_participant
- ledger: ledger_entry (amount>0, kind, soft delete deleted_at; owner_id denormalizado sem FK por ADR-007)

Relacionamentos criticos: envelope.owner_id e participant.user_id em CASCADE a partir de user_account; ledger_entry.envelope_id ON DELETE CASCADE; ledger_entry.author_id REFERENCES user_account sem ON DELETE explicito; participant.added_by REFERENCES user_account sem ON DELETE.

4. Pontos positivos (contexto)

- Flyway habilitado + hibernate.ddl-auto=validate + open-in-view=false.
- Money via BigDecimal/NUMERIC(19,2) e MoneyJpaConverter; CHECKs de nao-negatividade / amount>0.
- @Version em monthly_income e envelope; locks pessimistas em consumo de tokens/challenges; advisory lock em cadastro/rate-limit.
- Indices parciais para exclusao logica e tokens ativos; IdentityRetentionService agenda descarte diario (UTC 03:17).
- Testes de integracao com Testcontainers PostgreSQL 18.
- Segredos de sessao/recuperacao/MFA/OAuth persistidos como hash ou ciphertext; inventario de dados atualizado.

5. Matriz priorizada de achados

DB-001 | P1 | Alta | S | Listagem por verba ignora soft delete | Integracao ORM | Defeito
DB-002 | P1 | Alta | M | Soma-base <= renda nao aplicada no create/update | Integridade | Defeito
DB-003 | P1 | Alta | XS | oauth_mobile_handoff fora do job de retencao | Retencao | Defeito
DB-004 | P1 | Media | L | Backup/restauracao nao operacionalizados | Recuperacao | Risco
DB-005 | P2 | Alta | S | FKs author_id/added_by sem politica de exclusao de conta | Integridade | Risco
DB-006 | P2 | Media | S | CHECK annual_due_day aceita datas invalidas | Integridade | Risco
DB-007 | P3 | Media | S | Indice composto parcial para sumAmountUpTo | Performance | Hipotese
DB-008 | P2 | Media | L | Exclusao/exportacao do titular incompletas | Privacidade | Divida
DB-009 | P3 | Baixa | - | owner_id do ledger sem FK (ADR-007) | Modelagem | Aceitar
DB-010 | P3 | Baixa | - | Sem RLS; isolamento so na aplicacao | Seguranca | Aceitar no corte

6. Detalhamento dos achados

DB-001 — findFiltered nao filtra deleted_at

Categoria: integracao ORM / integridade. Severidade: alta. Prioridade: P1. Confianca: alta. Esforco: S.
Localizacao: LedgerEntryRepository.findFiltered; LedgerService.list.
Evidencia: a query JPQL filtra envelope/kind/mes mas omite deletedAt IS NULL; sumAmountUpTo e findHistory ja respeitam soft delete (V6 + consultas).
Tipo: defeito comprovado. Impacto: gastos excluidos reaparecem na lista da verba; UX e auditoria visual inconsistentes com o saldo.
Recomendacao: adicionar AND e.deletedAt IS NULL (ou parametro includeDeleted alinhado ao historico). Criterios: teste de API cria gasto, exclui, lista por verba vazia/sem o item; saldo inalterado.
Decisao sugerida: corrigir.

DB-002 — invariante soma das bases <= renda

Categoria: integridade. Severidade: alta. Prioridade: P1. Confianca: alta. Esforco: M.
Localizacao: EnvelopeService.create/update; MonthlyAllocationPlan (dominio existe mas nao e chamado); EnvelopeIncomeConstraint so em IncomeService.change.
Evidencia: fundacao-tecnica exige validar soma-base; ADR-007 §1.6 so cobre reducao de renda; handler AllocationExceedsIncomeException existe sem caminho de criacao.
Tipo: defeito comprovado (regra de negocio). Impacto: alocacao pode exceder renda; unallocated negativo mascarado no summary (clamp a zero).
Recomendacao: no create/update (e alteracao de base), carregar renda efetiva do mes e aplicar MonthlyAllocationPlan / equivalente sob a mesma transacao; considerar lock otimista da renda. Nao tentar CHECK SQL cross-table agora.
Criterios: POST envelope com base que estoura renda -> 400 allocation.exceeds_income; reducao de renda continua bloqueada.
Decisao sugerida: corrigir.

DB-003 — retencao de oauth_mobile_handoff

Categoria: retencao / privacidade. Severidade: alta (conformidade inventariada). Prioridade: P1. Confianca: alta. Esforco: XS.
Localizacao: IdentityRetentionService.discardExpiredTechnicalData; OAuthMobileHandoffRepository.deleteEndedBefore (ja existe); inventario (24h apos expiracao/consumo).
Evidencia: job limpa attempts, sessions, reset, MFA, recovery, oauth_authorization_state; nao chama mobileHandoffs.
Tipo: defeito comprovado. Impacto: hashes de handoff acumulam alem da retencao declarada.
Recomendacao: injetar repositorio e chamar deleteEndedBefore(now - 24h) no mesmo cron.
Decisao sugerida: corrigir.

DB-004 — backup e restauracao

Categoria: recuperacao. Severidade: alta para abertura publica. Prioridade: P1. Confianca: alta (docs). Esforco: L.
Localizacao: docs/privacy/* (pendente); compose volume postgres-data sem job pg_dump; ADR-010/012 adianto backup.
Tipo: risco estatico. Impacto: perda do volume Docker = perda de dados financeiros/pessoais;

RPO/RTO indefinidos.
Recomendacao: definir frequencia, cifrar, retenção, teste de restauracao em ambiente isolado e runbook antes de cadastro publico.
Validacao: restaurar dump sintetico e conferir Flyway + login. Sem teste = nao verificado.
Decisao sugerida: planejar / mitigar (nao executar dump nesta auditoria).

DB-005 — FKs e exclusao de conta

Categoria: integridade / migracoes. Severidade: media-alta. Prioridade: P2. Confianca: alta.
Esforco: S-M.
Localizacao: V4 envelope_participant.added_by; V5 ledger_entry.author_id (REFERENCES sem ON DELETE); status DELETED em user_account sem fluxo de exclusao.
Evidencia: DELETE de usuario que e author em verba de terceiros falha por FK; added_by idem. Cascata de envelopes proprios nao resolve autoria em verbas compartilhadas.
Tipo: risco estatico (bloqueia direito do titular quando implementado).
Recomendacao: ao desenhar exclusao, escolher ON DELETE RESTRICT+anonimizacao de author_id, SET NULL (se coluna permitir) ou preservar UUID orfao com FK removida — com ADR. Nao CASCADE em author_id (apagaria historico alheio).
Decisao sugerida: investigar com o ADR de exclusao do titular.

DB-006 — vencimento anual invalido no CHECK

Categoria: integridade. Severidade: media. Prioridade: P2. Confianca: alta. Esforco: S.
Localizacao: V8 envelope_financial_configuration_check (annual_due_day 1..31).
Evidencia: aceita 31/02 etc.; dominio Java MonthDay.of rejeita invalidos se passado pela API tipada, mas o banco sozinho nao.
Tipo: risco. Recomendacao: validacao forte na aplicacao (ja parcialmente) + opcionalmente rejeitar combinacoes invalidas em CHECK ou trigger; documentar.
Decisao sugerida: mitigar na aplicacao; CHECK sofisticado e opcional.

DB-007 — indice para agregacoes de saldo

Categoria: performance. Severidade: baixa sem volume. Prioridade: P3. Confianca: media.
Esforco: S.
Localizacao: sumAmountUpTo (envelope_id, kind, occurred_at, deleted_at IS NULL); indices atuais: (envelope_id, occurred_at), (envelope_id, kind), parcial (occurred_at, created_at) WHERE deleted_at IS NULL.
Tipo: hipotese. Sem EXPLAIN nao recomendar indice definitivo.
Recomendacao: medir com EXPLAIN (sem ANALYZE em prod) em ambiente de teste com dados sinteticos; so entao criar (envelope_id, kind, occurred_at) WHERE deleted_at IS NULL CONCURRENTLY.
Decisao sugerida: adiar / medir.

DB-008 — direitos do titular incompletos

Categoria: privacidade / operacao. Severidade: media. Prioridade: P2. Confianca: alta (docs).
Esforco: L.
Evidencia: requisitos pedem exportacao/correcao/exclusao; operacao-de-renda marca fluxo pendente; cascata SQL existe parcialmente mas nao ha API/job de exclusao verificavel nem propagacao a backups.
Tipo: divida tecnica / risco de conformidade para abertura publica.
Decisao sugerida: planejar com juridico + DB-004/DB-005.

DB-009 — owner_id sem FK

Intencional (ADR-007 denormalizacao). Risco residual baixo se mutacoes so pela API. Decisao: aceitar; nao adicionar FK sem revisitar ADR.

DB-010 — ausencia de RLS

Isolamento por queries da aplicacao (owner OR participant). Adequado ao monolitico atual. RLS seria defesa em profundidade se houver multiplos papeis SQL — fora do corte. Decisao: aceitar agora.

7. Transacoes, consultas e migracoes

- Transacoes: servicos usam @Transactional; consumo de segredos com PESSIMISTIC_WRITE; AuthAttempt/UserAccount com pg_advisory_xact_lock — adequado.
- N+1: listagens de historico carregam envelopes em mapa apos query — padrao aceitavel no volume atual.
- Migracoes V1-V12 versionadas e evolutivas (expand de colunas anuais/metas); V3 fez backfill de password_hash — historico limpo.
- Hibernacao validate evita drift silencioso.

8. Seguranca, backup e observabilidade

- Credenciais: defaults locais em application.yml/compose marcados como change-me / test-only; producao deve usar secrets (docs/deploy). Valores nao reproduzidos neste relatorio.
- TLS/borda: documentados em ADR-012; fora do schema.
- Backup: nao verificado / pendente (DB-004).
- Observabilidade DB: management expoe health/info; sem slow query log dedicado no repositorio.

9. O que nao recomendo fazer agora

- Nao particionar/sharding PostgreSQL.
- Nao introduzir cache (Redis/Caffeine) — regra do projeto.
- Nao criar indices em massa sem EXPLAIN.
- Nao adicionar FK em ledger.owner_id sem ADR.
- Nao executar migrações destrutivas nem EXPLAIN ANALYZE em producao nesta etapa.
- Nao implementar microservicos de dados.

10. Plano de melhoria por fases

Fase A (corrigir ja): DB-001, DB-003.
Fase B (regra financeira): DB-002 com testes TDD.
Fase C (operacao/LGPD): DB-004, DB-008, desenho DB-005.
Fase D (higiene): DB-006; medir DB-007 se volume crescer.

Riscos de rollout: DB-002 muda contrato de API (novos 400); DB-005 exige ADR antes de migrar FKs; backups exigem secrets e teste isolado.

11. Decisoes solicitadas

Aprovar IDs para criacao de issues GitHub (gh). Exemplos: DB-001, DB-002, DB-003.
Aprovar o relatorio NAO cria issues automaticamente.
Banco, schema e codigo NAO foram alterados nesta auditoria.
gh auth esta invalido — reautenticar antes da Fase 8.

12. Apendice — referencias

- backend/src/main/resources/db/migration/V1..V12
- LedgerEntryRepository.java, LedgerService.java, EnvelopeService.java, IdentityRetentionService.java
- docs/ideas/fundacao-tecnica.md, docs/decisions/0006, 0007, 0009
- docs/privacy/inventario-de-dados.md, requisitos-de-seguranca.md, operacao-de-renda.md
- compose.yaml (postgres:18-alpine), application.yml (flyway, jpa validate)

Verificacoes executadas: leitura estatica do repositorio; git status; checagem de ferramentas PDF/gh. Sem consulta SQL ao servidor.